



Cibersegurança Cybersecurity

(METI 1º Ano/S2 - 6707N5)

Teresa Pereira (tpereira@dsi.uminho.pt)
Dpt. Sistemas de Informação

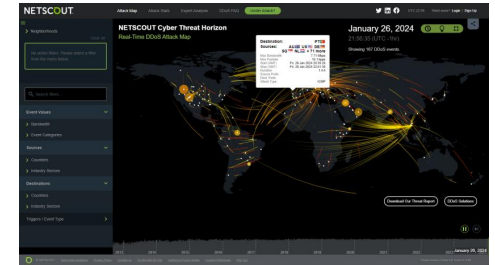


Todos os conteúdos disponibilizados são da autoria do Prof. Henrique Santos (hsantos@dsi.uminho.pt)

Dpt. de Sistemas de Informação
Universidade do Minho

Cybersecurity Skills Gap

- Every 39 seconds, a cyberattack happens
- Millions of Cybersecurity jobs are unfilled
- Organizations struggle to find skilled professional



There will be
3.5 Million
Unfilled cybersecurity jobs globally in 2024

CYBERCRIME MAGAZINE

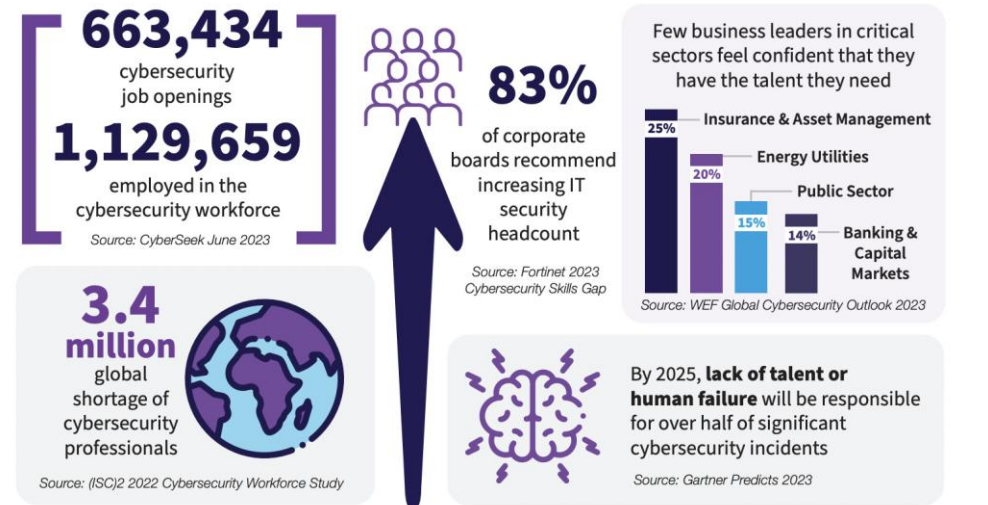
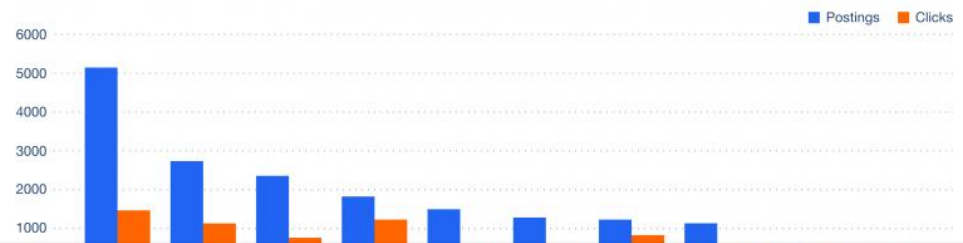
Cybersecurity Job Market

<https://www.indeed.com/lead/cybersecurity-skills-gap-report>

- Growing demand vs. Available professionals
- Challenges:
 - ❑ lack of training
 - ❑ fast-changing threats
 - ❑ hiring barriers

Cyber Security Skills Deficit Persists Across Countries

Cyber security postings and clicks per million postings and clicks (2016Q3)



<https://identitytheft.org/statistics/cyber-security/>

How to Start a Cybersecurity Career?

- No experience? No problem!

- Learn online: TryHackMe, Hack The Box, Cybrary...
- Get certified: CompTIA Security+, Google Cyber Cert...
- **Gain hands-on experience:** Cyber Ranges, CTFs, general exercises, working...



The Importance of Hands-On Training

- Theory vs Practice (or Education vs Training)
 - ❑ *Traditional* training: too much theory
 - ❑ Hands-on labs: *real-world attack simulations* and **intensive real-tools practice exercises**
 - ❑ Tools: Kali Linux, Wireshark, Metasploit...



ESSI



Careers in Cybersecurity

■ Several frameworks

- ❑ NICE Cybersecurity Workforce Framework (NIST SP 800-181)
- ❑ European Cybersecurity Skills Framework (ECSF)
- ❑ ...

■ Main target professions (ECSF)

Cyber Threat Intelligence Manager	Cybersecurity Architect
Cybersecurity Implementer	Specialist Cybersecurity Risk
Cybersecurity Research	Chief Information Security Officer (CISO)
Cyber Incident Responder	Penetration Tester

Common Pitfalls in Cyber Training

- Why training fails (sometimes):
 - ❑ Too generic, or outdated
 - ❑ No real-world application
 - ❑ **One-time event** instead of *ongoing learning*
- Solution: **Continuous**, role-based, **engaging training**

Summary

- InfoSec Fundamentals
 - Simple Model for InfoSec (ISO/IEC 27k)
 - Attacks, Threats and Vulnerabilities in computer networks
 - InfoSec Policies
- Applied cryptography
- Access Control
- Security in TCP/IP based networks
- InfoSec Technologies
 - Firewalls
 - Intrusion Detection Systems
 - Security Protocols
 - IPSec
 - SSL/TLS
 - VPN
 - ...
 - Biometrics
 - ...
- IoT and Web Security (☺)
- Introduction to forensic analysis (☹)
- Cyber Intelligence
- Operating System Security / Computer Security
- Security Evaluation
- Security Management and Auditing

Teaching Objectives

- Develop essential knowledge on various information security technologies as well as the technical skills required for its correct implementation, which together are critical to enabling a conscious and effective involvement in **designing and implementing an Information Security Management process**; and
- Awareness about issues (technical, personal, organizational, educational, etc.) related to the topic of Information Security in the current context of "Cyberspace" (basic Cyber Intelligence competencies)

Learning Outcomes

- **Recognize** the importance of a culture of security with respect to the use of computer systems and networks
- **Identify** the technical aspects of computer systems and networks that expose them more to security risks
- **Recognize** the main threats and the typical way the attacks are carried out
- **Analyze** vulnerabilities in networked systems
- **Plan** security strategies for networked computers
- **Implement** continuous management and control processes, defined in the context of a security policy for networked computers
- **Use** security analysis and auditing tools for computer and networks

Assessment Strategy

- Homework & Exercises (65%~75%)
- Final “cyber exercise” or essay (10%~25%)
- Participation in class initiatives (10%~15%)
- Late delivery concerning homework and other evaluation material is accepted with a penalty of 5%/hour!
- Attendance control in theoretical lessons is applied, but there are no absence limit. In the TPs **is mandatory** the presence of the 2/3 classes
- The UC monitoring will be done by Moodle platform (<https://e-learning.dsi.uminho.pt>)

Assessment Strategy

■ Homework & Exercises

Risk Analysis (2 weeks)

- Application of a RA (Risk Assessment) simple method to a particular situation

Access Control (2 weeks)

- Use a formal model to specify an Access Control policy in a particular environment

Basic PKI deployment & Management (2 weeks)

- Use OpenSSL (or ADSS, or ...) to deploy and use a typical (simple) PKI

Network Traffic analysis (2 weeks)

- Use network security tools to understand network vulnerabilities and perform traffic analysis

Network Security – Firewall & IDS (2 weeks)

- Use open source tools to implement fundamental network security functions (traffic filters and intrusion detection)



Computer Security & Pen Testing (3 weeks)

- Experimenting attack tools and assess vulnerability's exploits impact



Final Pen Test Exercise

Contributes to tools mastering

- Virtualization
- Kali
- Linux (security-related commands)
- Shibboleth / Keycloak / OpenLDAP (Active Directory) / OpenID Connect / OAuth2 ...
- Kerberos
- OpenSSH
- OpenSSL
- PGP (GnuPG)
- Wireshark
- pfSense
- Suricata / Snort / Zeek
- Security Onion / OSSIM / ELK...

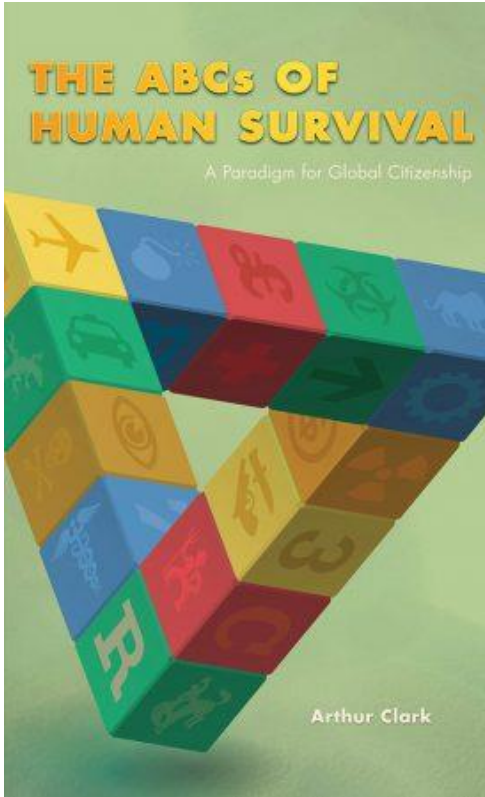
Bibliography

- **Santos, Henrique M. D., “Cybersecurity: A Practical Engineering Approach”, 1st edition, Chapman and Hall/CRC, 2022 (ISBN 9780367252427) [link](#)**
- Pfleeger, Charles P., Pfleeger, Shari L., and Coles-Kemp, L., “Security in Computing”, 6th Edition, Addison-Wesley Prof, 2023
- Stallings, W., “Cryptography and Network Security: Principles and Practice, Global Ed”, 8th Edition, Pearson Education Limited, 2022
- Anderson, R. J. , “Security Engineering: A Guide to Building Dependable Distributed Systems”, 2nd Ed., Wiley Publishing, 2008. (<http://www.cl.cam.ac.uk/~rja14/book.html>) – 3rd Ed. Published 2021
- Kaufman, C., Perlman, R., Speciner, M., and Periner, R. “Network Security: Private Communication in a Public World”. 3rd ed., Addison-Wesley Professional, 2023
- Stamp, M., “Information Security: Principles and Practice”, 3rd edition, Wiley, 2021
- Bishop, M., “Introduction to Computer Security”, Addison-Wesley, 2005.
- Santos, H. D., “A norma das normas em Segurança da Informação”, Publicação da Associação Portuguesa para a Qualidade, XXXV, 1 (Primavera, 2006), 11-19.
- Zúquete, A., “Segurança em Redes Informáticas”, 3^a ed., FCA – Editora Informática, 2010.

- CERT Coordination Center, <http://www.cert.org/>
- NIST Computer Security Division 893 and CSRC Home Page, <http://csrc.nist.gov/>
- Resources for Security Risk Analysis, Security Policies, ISO 17799 (or BS7799) and Security Audit, <http://www.securityauditor.net/>
- The Computer Security Institute, <http://www.gocsi.com/>
- ...



Initial Reflection



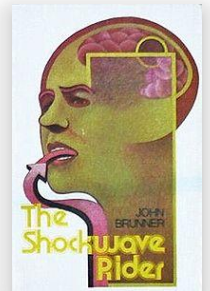
♦ [This Photo](#) by Unknown Author is licensed under [CC BY-NC-ND](#)

“The world is never going to be perfect, either on- or offline; so, let’s not set impossibly high standards for online.”

— Esther Dyson

Contextualization

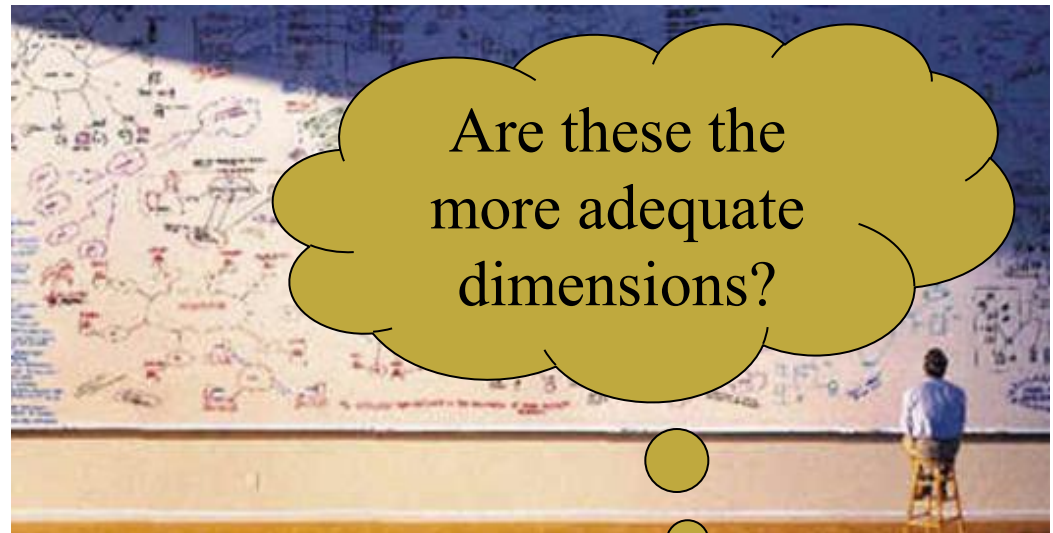
- Evolution of information technology (≈60 years)
 - ❑ Few computer centers isolated
 - ❑ Time-sharing
 - ❑ Data networks (Distributed Systems)
 - ❑ Personal computers
 - ❑ Ubiquitous computing, mobility and the technology convergence
- The first “worm”
 - ❑ In 1975, the scientific fiction classic from John Brunner, *The Shockwave Rider*, provided the first computer program that replicates itself and propagates itself



Contextualization

■ Complexity:

- ❑ Non rigorous engineering process
- ❑ Legacy systems (developed in more trustable environments)
- ❑ Component integration (COTS) - modular approach
- ❑ Diversity and flexibility
- ❑ Short life cycle
- ❑ Highly complex sw stacks
- ❑ ...



■ Risks:

- ❑ Availability
- ❑ Confidentiality
- ❑ Integrity

Technological complexity



≈ 2,1 Mil Milhões de transístores em $1,2\text{cm}^2$

≈ 50 Milhões de operações por segundo

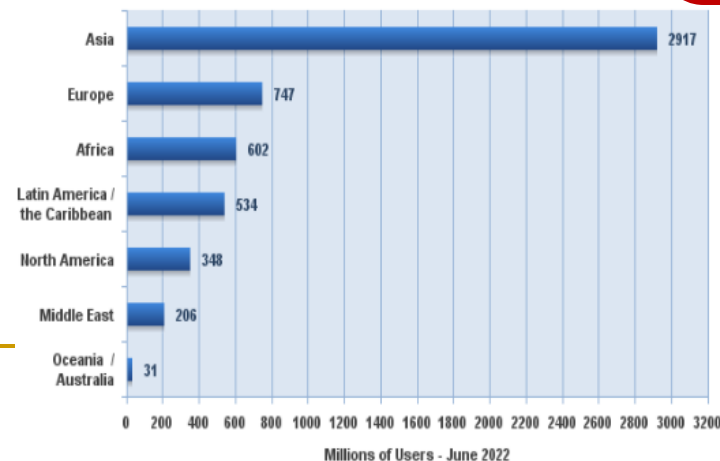


[illegible]

Social complexity

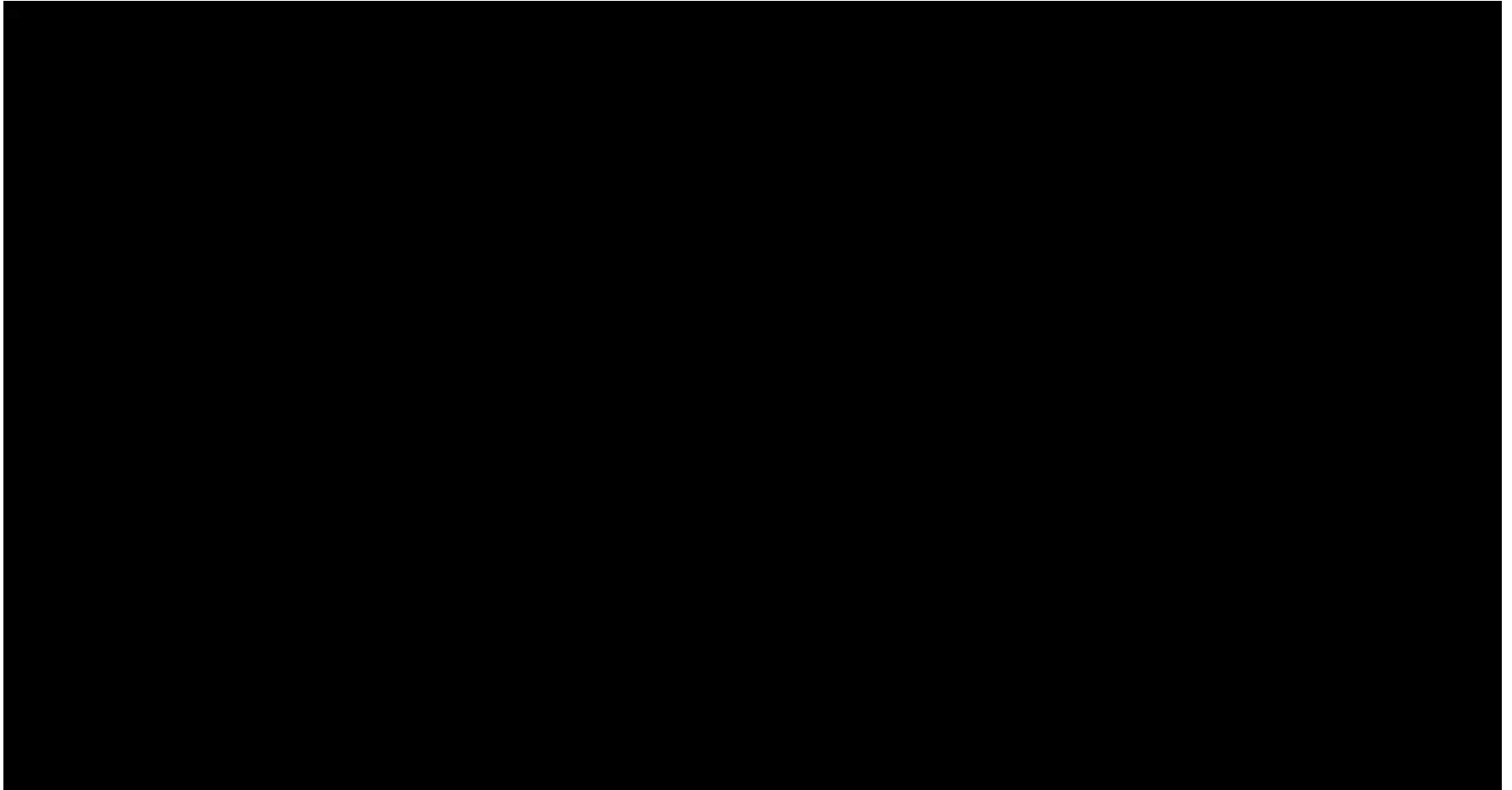
- Internet statistics

WORLD INTERNET USAGE AND POPULATION STATISTICS 2023 Year Estimates						
World Regions	Population (2022 Est.)	Population % of World	Internet Users 31 Dec 2021	Penetration Rate (% Pop.)	Growth 2000-2023	Internet World %
Africa	1,394,588,547	17.6 %	601,940,784	43.2 %	13,233 %	11.2 %
Asia	4,352,169,960	54.9 %	2,916,890,209	67.0 %	2,452 %	54.2 %
Europe	837,472,045	10.6 %	747,214,734	89.2 %	611 %	13.9 %
Latin America / Carib.	664,099,841	8.4 %	534,526,057	80.5 %	2,858 %	9.9 %
North America	372,555,585	4.7 %	347,916,694	93.4 %	222 %	6.5 %
Middle East	268,302,801	3.4 %	206,760,743	77.1 %	6,194 %	3.8 %
Oceania / Australia	43,602,955	0.5 %	30,549,185	70.1 %	301 %	0.6 %
WORLD TOTAL	7,932,791,734	100.0 %	5,385,798,406	67.9 %	1,392 %	100.0 %



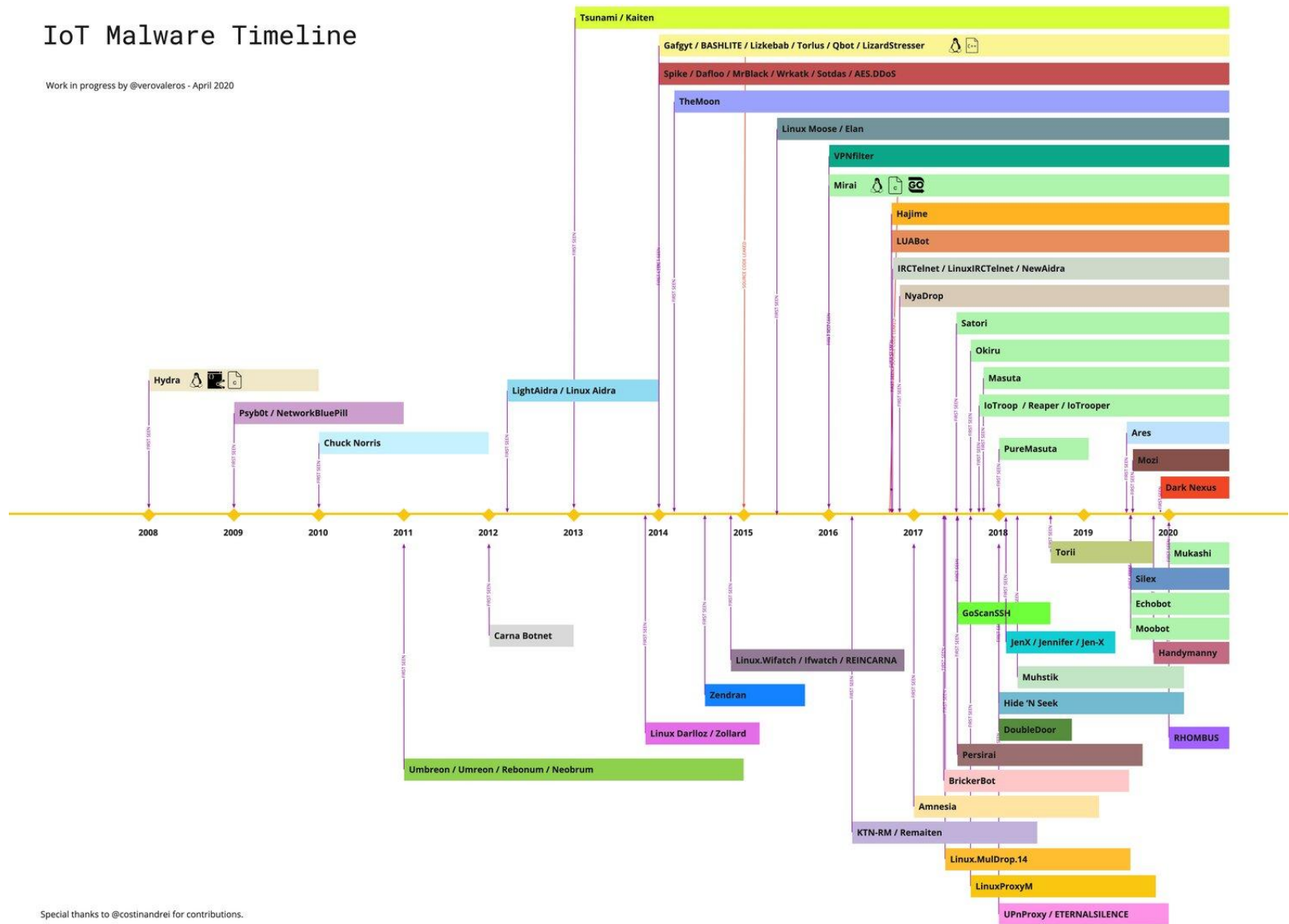
<http://www.internetworldstats.com/stats.htm>

Introduction to IoT (@NIST)



IoT Malware Timeline

Work in progress by @verovaleros - April 2020

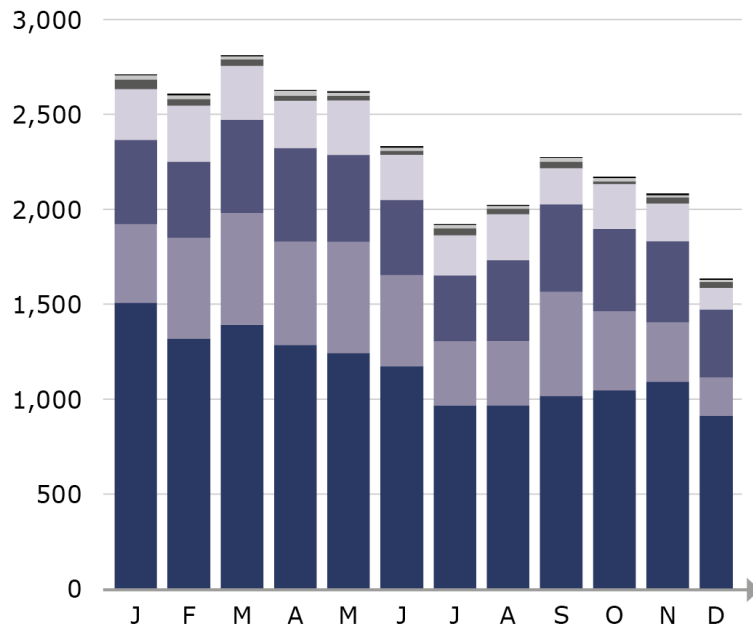


Special thanks to @costinandrei for contributions.

<https://www.stratosphereips.org/blog/2020/4/26/timeline-of-iot-malware-version-1>

Security incidents evolution

Cyber Crime Incidents Reported to Action Fraud in 2022.



Cyber Crime Type	2022 Total	% of Total
Denial of Service Attack	73	0.26%
Hacking Server	207	0.75%
Ransomware	373	1.31%
Hacking Extortion	2,829	10.07%
Hacking Personal	5,157	18.80%
Computer Virus Malware Spyware	5,324	19.08%
Hacking Social Media & Email	13,986	49.73%



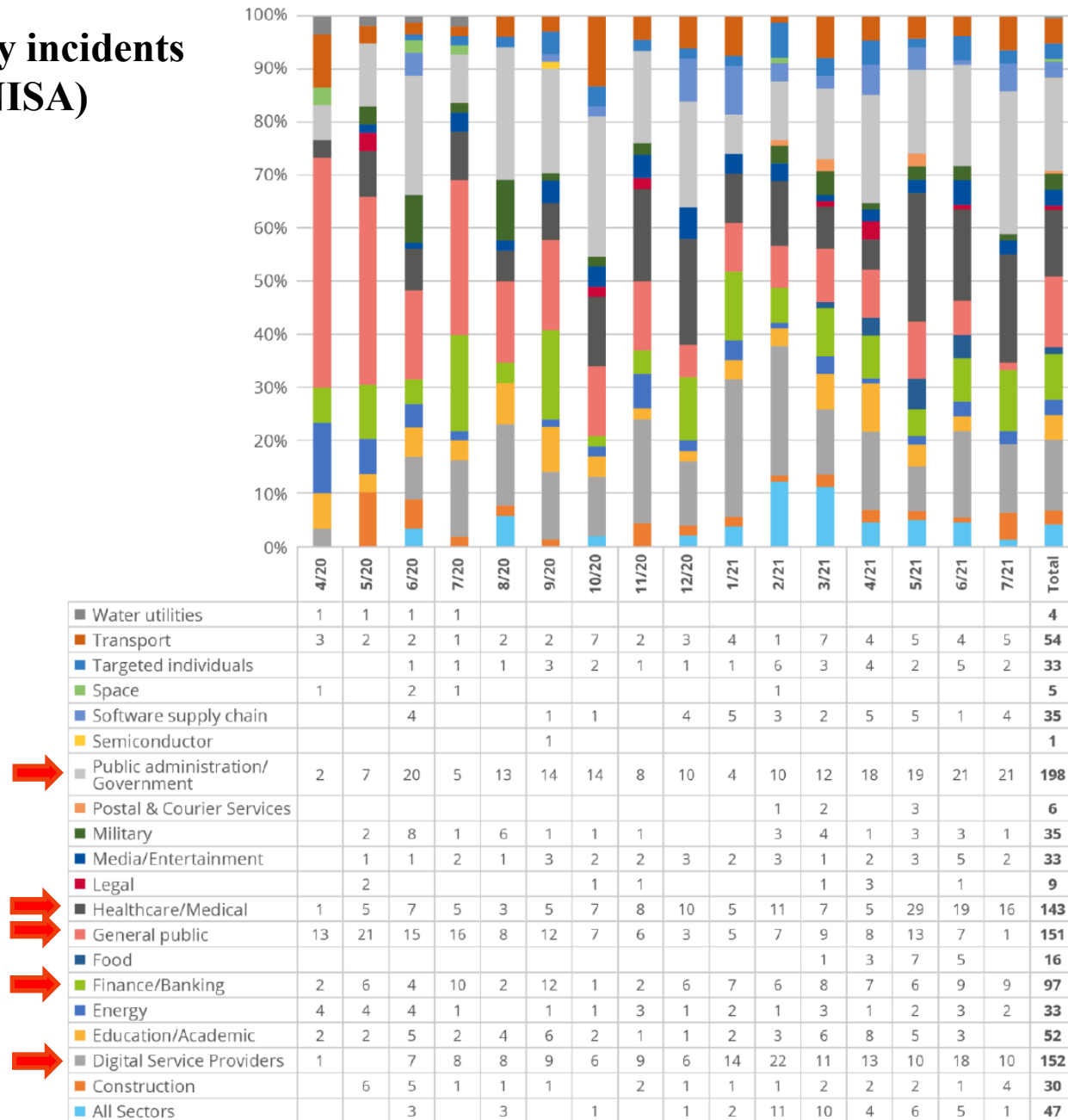
Hacking of social media and email accounts for over 49% of reported cyber crime incidents, according to Action Fraud.

Source: Action Fraud, Online Dashboard.

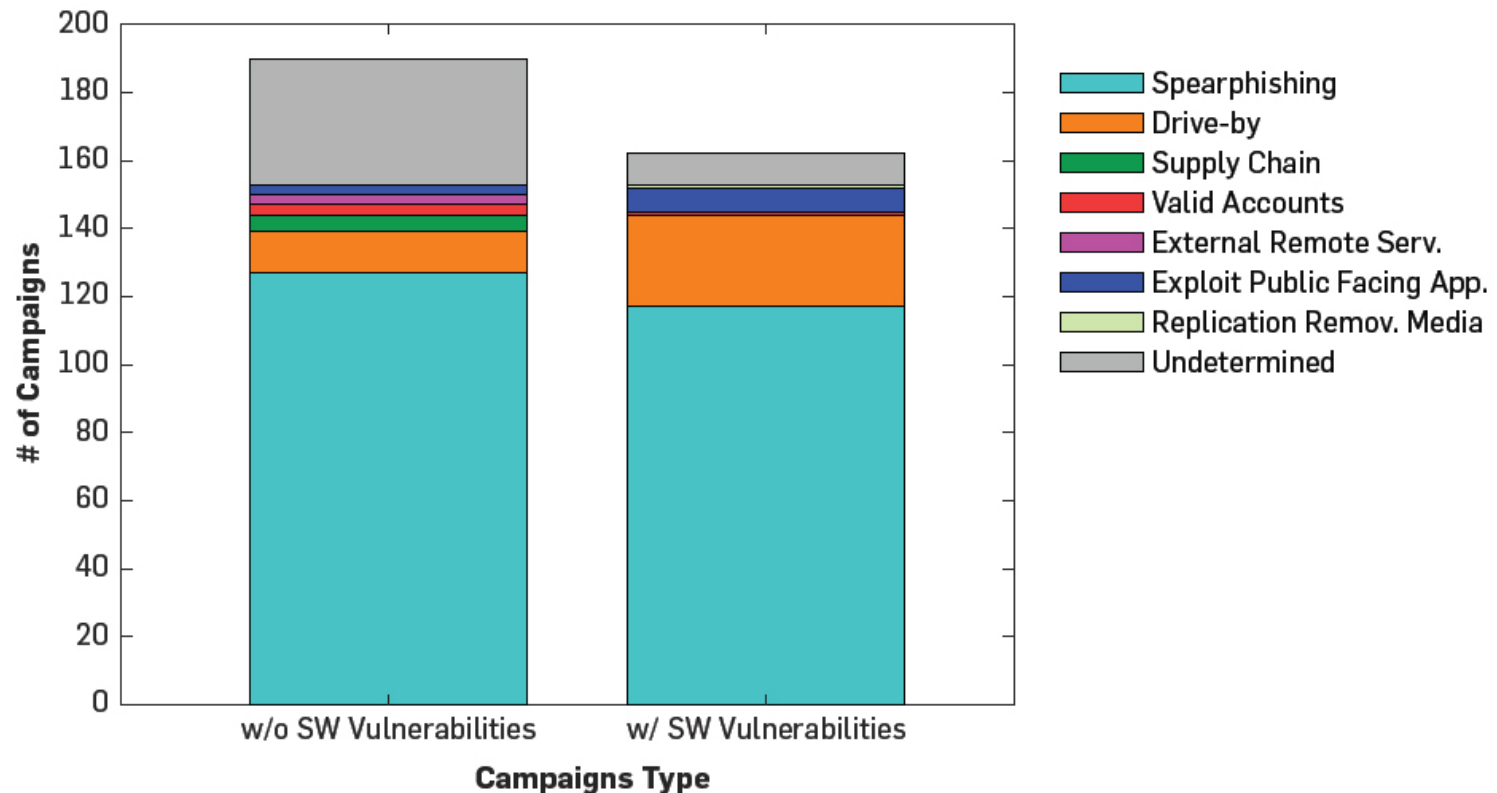
<https://nationalcrimeagency.gov.uk/nsa-cyber-crime>

Figure 3: Timeline of observed incidents related to prime ETL threats in terms of the affected sector.

Cybersecurity incidents by sector (ENISA)



APT – Advanced Persistent Threats



Attack vector campaigns and software vulnerabilities. More than half of the campaigns do not exploit software vulnerabilities but extensively rely on spearphishing to get initial access.

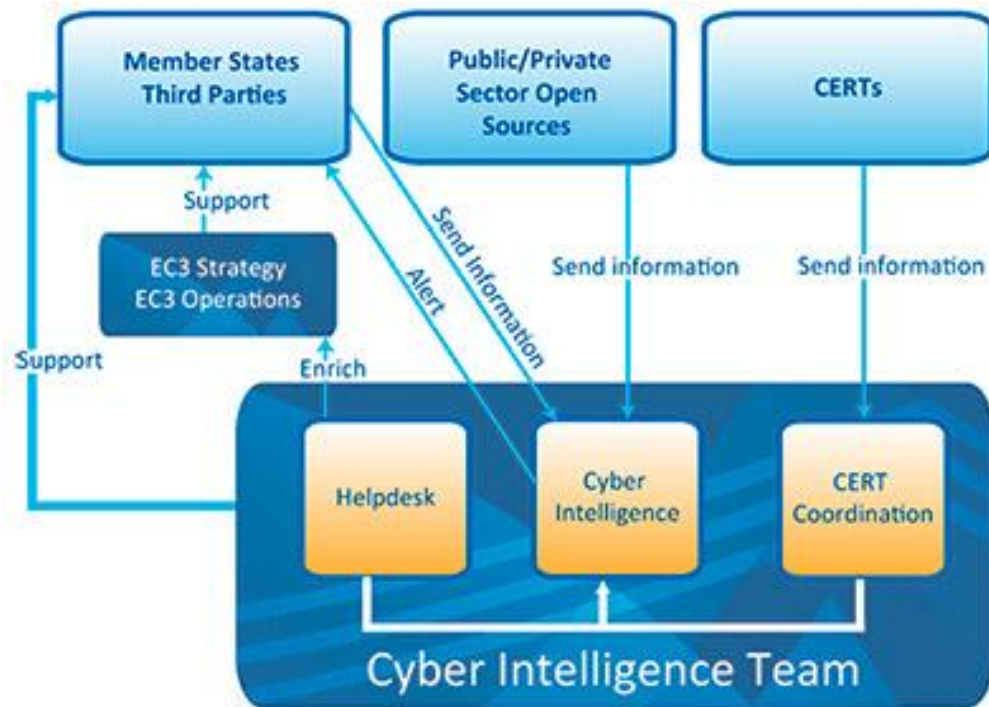
Cyber Intelligence

Cyber Intelligence is acquiring, processing, analyzing and disseminating information that identifies, tracks, and predicts threats, risks, and opportunities inside the cyber domain to offer courses of action that enhance decision making.

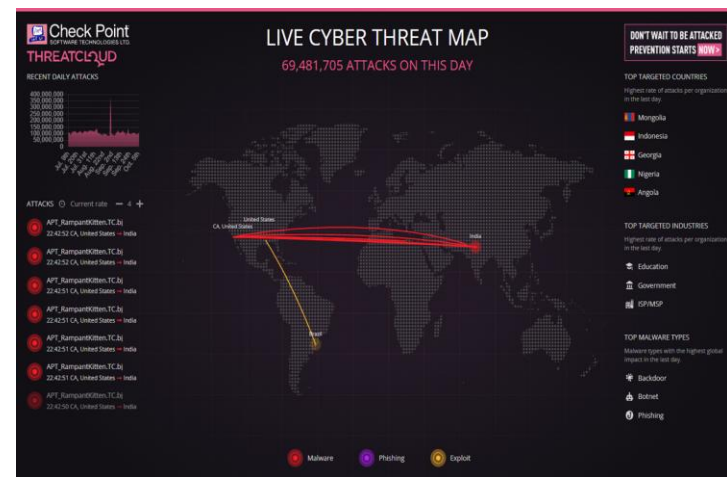
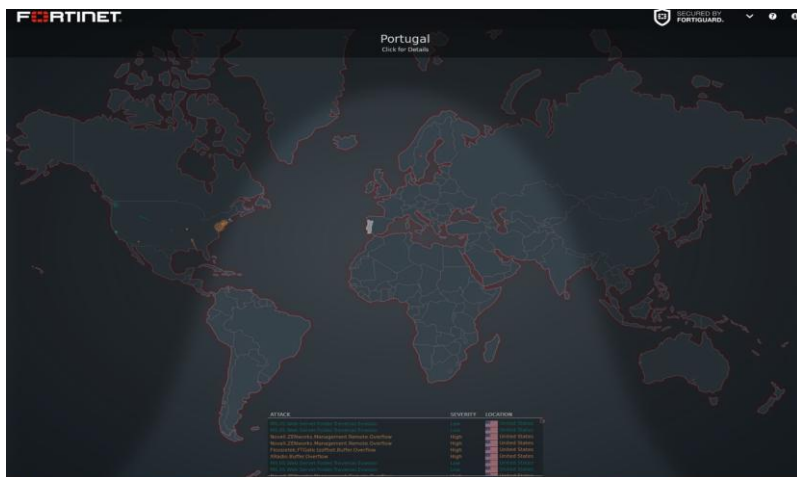
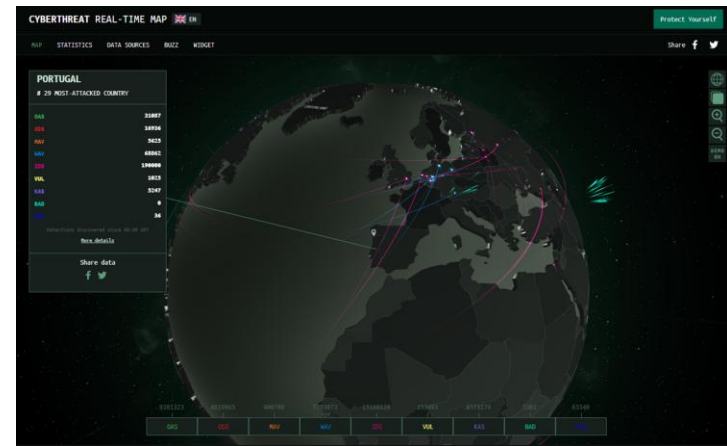
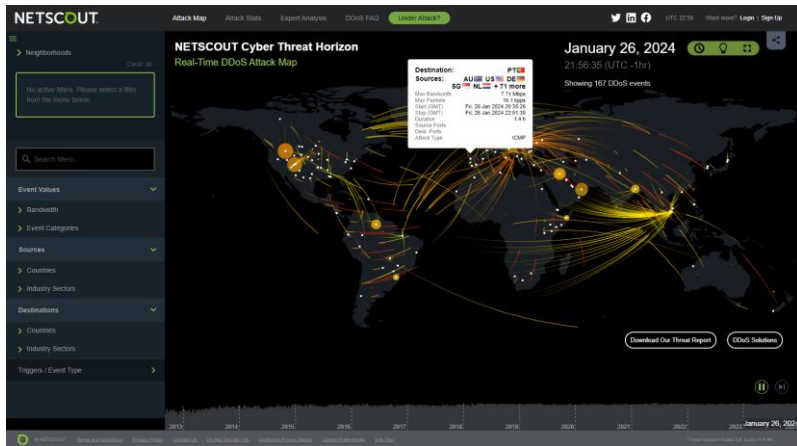
CISA | CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY

Cyber Intelligence

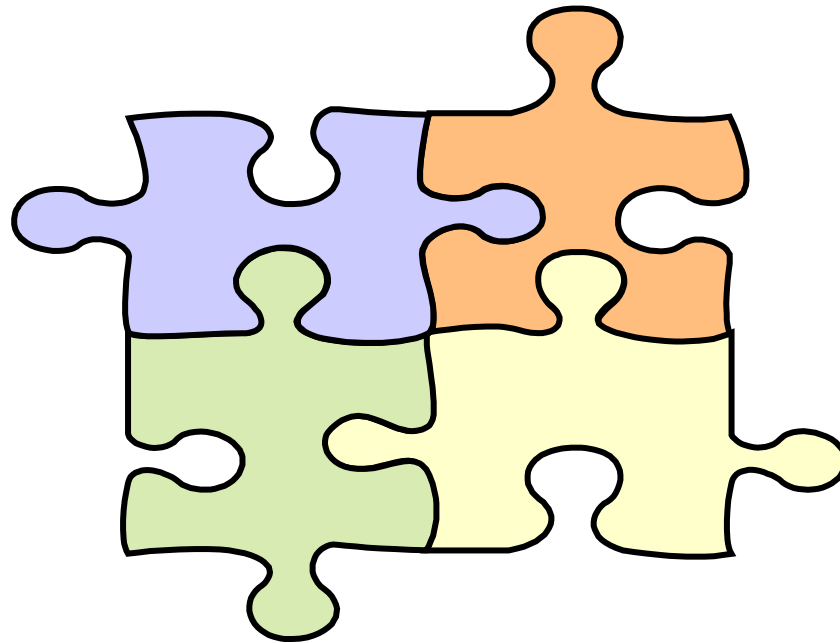
How the Europol sees it



Cyber Threat Maps



What security/safety measures (controls) are available, which should be used and **when** and **how** to implement them?



InfoSec fundamental concepts

- **Security** is a “measure” of **dependability** (quality of a system that allows us to trust, in a justified way, in its service) against **faults** affecting integrity, confidentiality and availability (!?)
- Security is not **safety**... but security contributes to safety
- And security is also not **privacy**, although it helps promote it



InfoSec fundamental concepts

- Terms and definitions (ISO/IEC 27000)
 - Resource
 - Any good or asset that **has value** to the organization
 - Information Security Event
 - Occurrence in a system, service or network, of an **identifiable state** which shows:
 - A possible **violation of security policy**;
 - A **failure of a defense**; or
 - A previously unknown situation with security relevance
 - Security Incident
 - Occurrence of one or more unexpected or unwanted security events, which have a **significant probability of compromising the operation of the organization** and threaten the information security.

(Bosworth, 2002)

InfoSec fundamental concepts

■ Terms and definitions (ISO/IEC 27000)

□ Controls

- ‘means of managing *risk*, including *policies, procedures, guidelines, practices* or organizational structures, which can be of *administrative, technical, management, or legal* nature. Control is also used as a synonym for safeguard or countermeasure’

□ Risk

- ‘*Effect of uncertainty* on objectives’
... ‘An effect is a deviation from the expected — positive or negative’
... ‘Uncertainty is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event, its consequence, or likelihood’
...

(ISO 27000, 2012)

InfoSec fundamental concepts

- ❑ **Security objectives** – preservation of certain information properties (or attributes) :

- C** ■ **Confidentiality**

- ❑ Restricted access to legitimate users

- I** ■ **Integrity**

- ❑ Content is not modified unexpectedly

- A** ■ **Availability**

- ❑ Accessible when needed

- **Authenticity**

- ❑ Unambiguous identification of the **responsible**

- **Utility**

- ❑ It serves the **purpose** for which it was created

- **Possession**

- ❑ Sole control by the **holder**

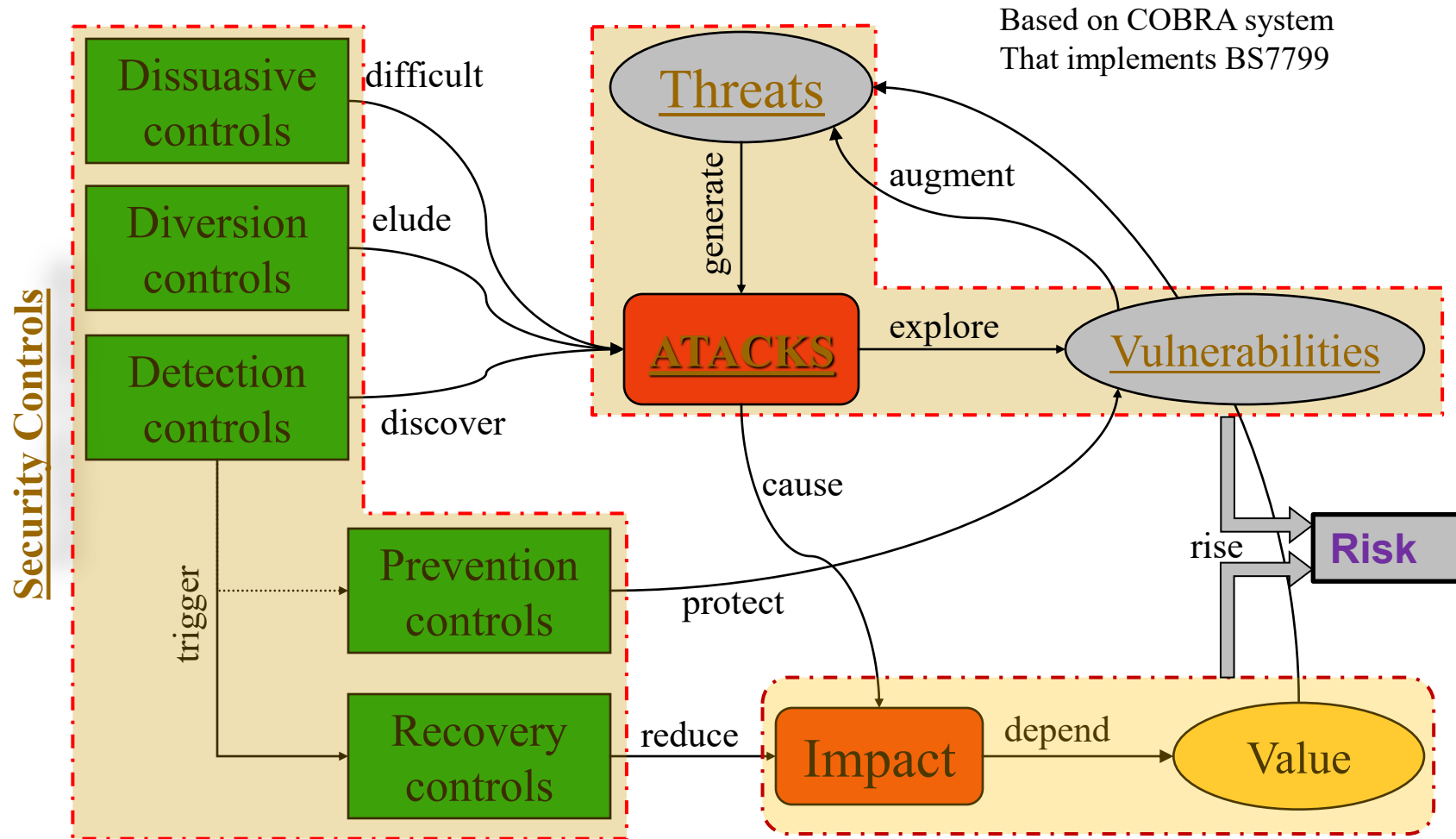
Integrity

Availability?!

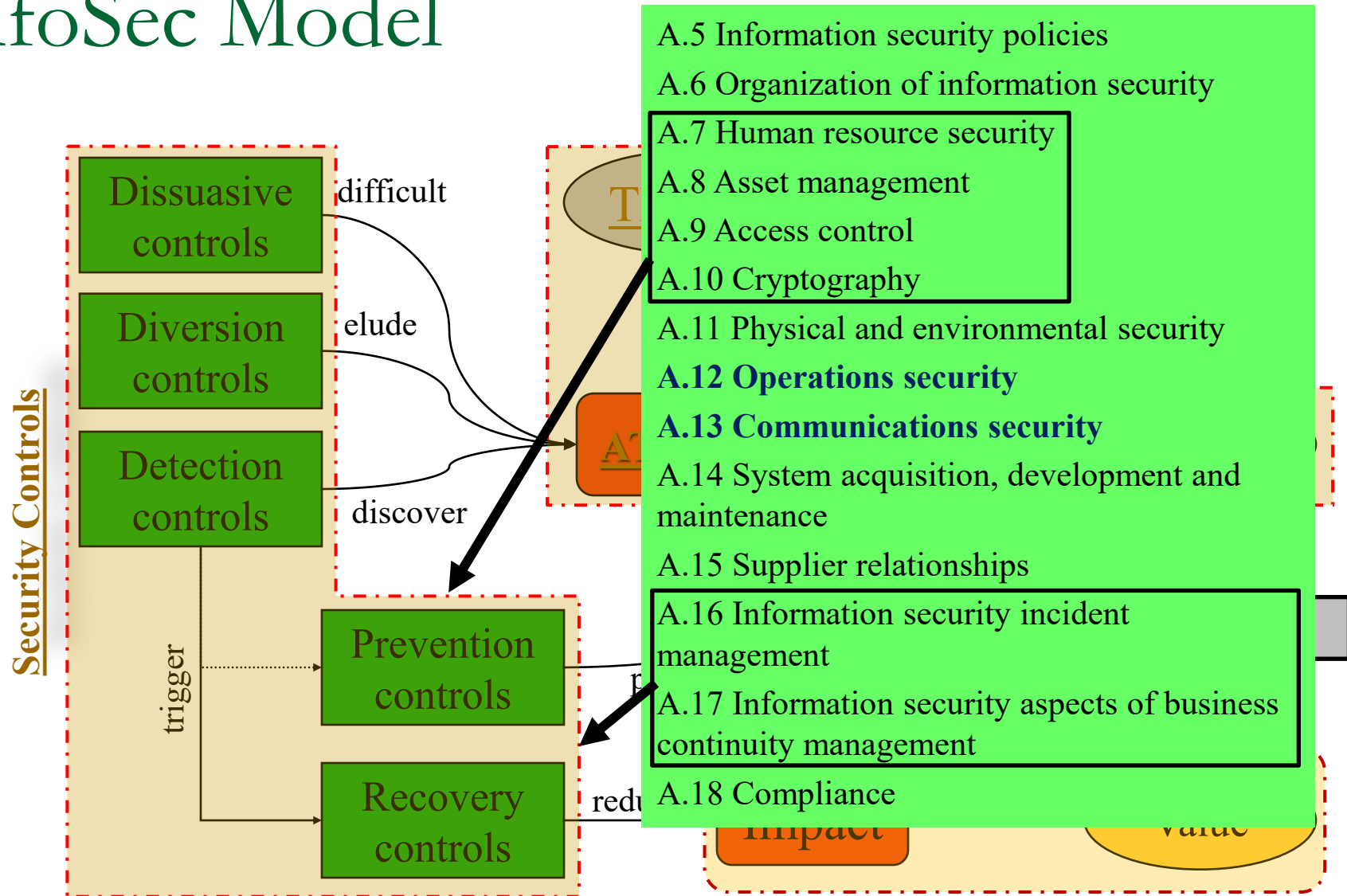
Availability

Confidentiality?!

InfoSec Model

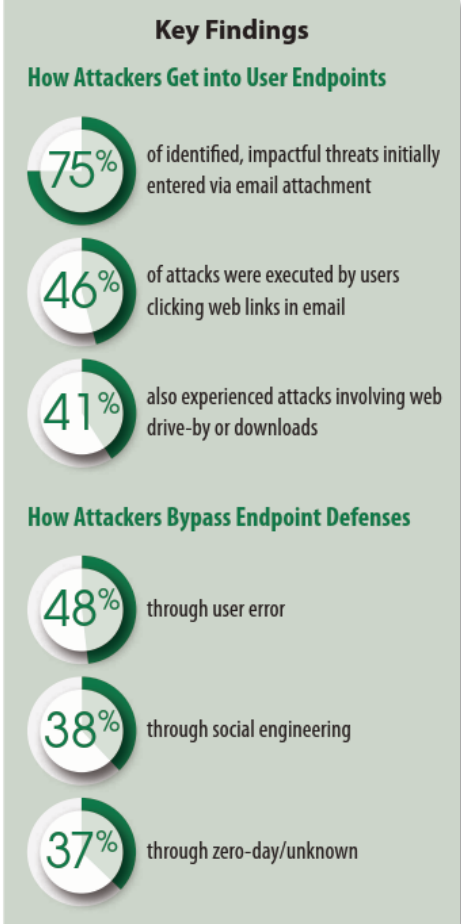


InfoSec Model



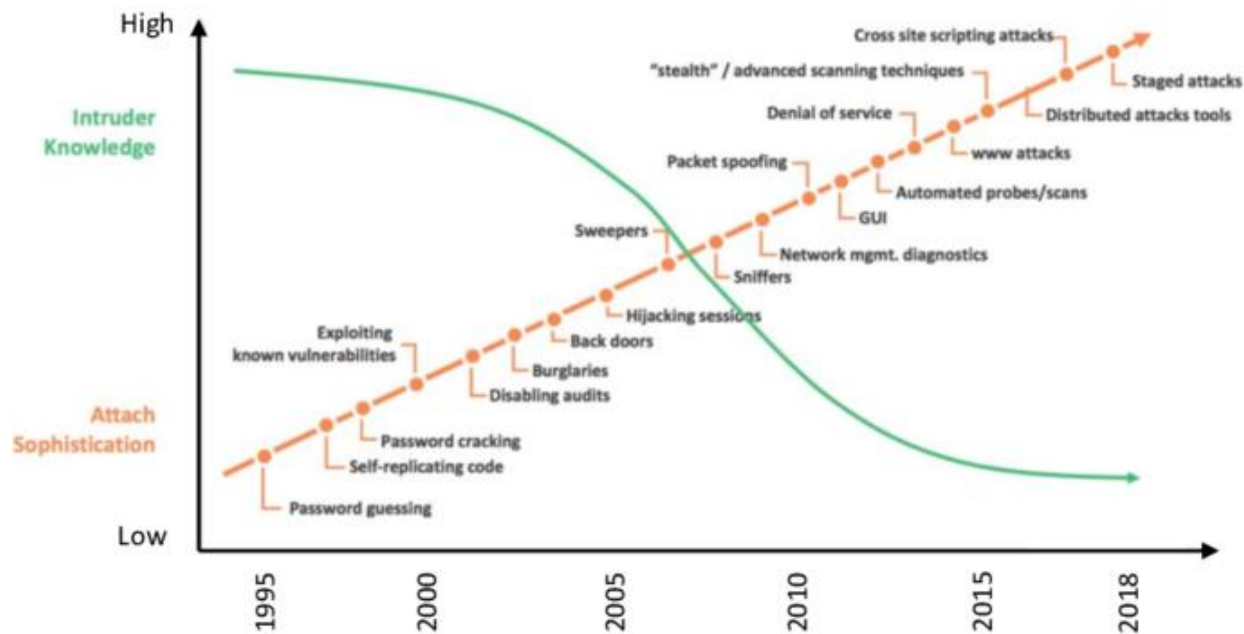
```

graph TD
    Amenazas[Amenazas] --> Ataques[ATAQUES]
    Amenazas --> Descubiertos[Medidas de Detección]
    Amenazas --> NoDescubiertos[Medidas de Prevención]
    Amenazas --> NoAtaques[no ataques]
    Amenazas --> Potencial[potencial]
    Ataques --> Descubiertos
    Ataques --> NoDescubiertos
    Ataques --> Vulnerabilidad[Vulnerabilidad]
    Ataques --> Impacto[Impacto]
    Descubiertos --> Vulnerabilidad
    Descubiertos --> Impacto
    NoDescubiertos --> Impacto
    Vulnerabilidad --> Impacto
    Vulnerabilidad --> Valor[Valor]
    Valor --> Impacto
    Impacto --> Vulnerabilidad
    
```



Exploits at the Endpoint: SANS 2016 Threat Landscape Survey

Threat Landscape



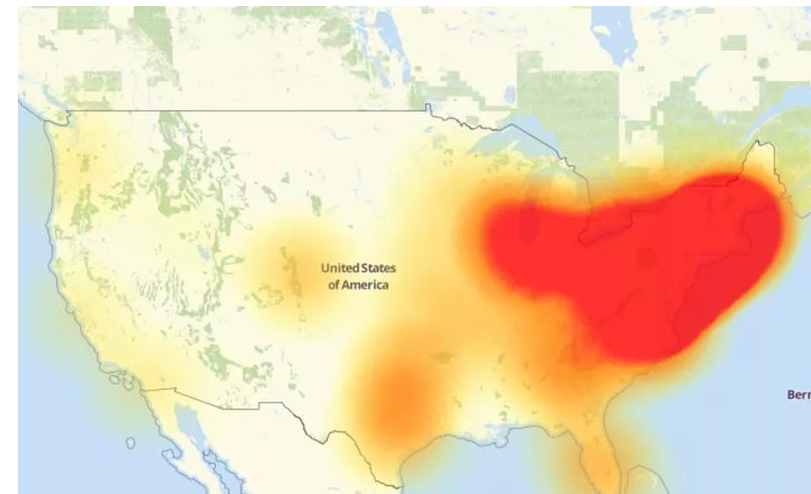
Fonte [Attacks cost vs sophistication \(CPS\).jpg](#)

Threat Landscape



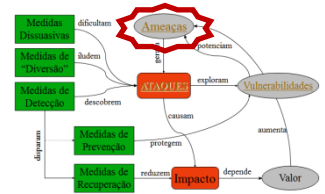
Denial-of-service attacks are shutting down major websites across the internet

- Starting at **11:10 UTC on October 21th-Friday 2016** we began monitoring and mitigating a DDoS attack against our Dyn Managed DNS infrastructure. Some customers may experience increased DNS query latency and delayed zone propagation during this time. Updates will be posted as information becomes available.
- ...
- **The Department of Homeland Security is reportedly investigating the incidents.**
- Several other websites were shut down as an apparent result of the attack. Among those appeared to be Reddit, Airbnb, Tumblr, Amazon, and The New York Times, although the final list of those affected seems to be much longer.
- ...
- **Update October 21st, 9:49AM ET: In another update, Dyn says the issues have been resolved.**
- **Update October 21st, 1:02PM ET: Dyn now writes it is once again under attack.**
- **Update October 21st, 4:28PM ET: Dyn reportedly hit by a third DDoS attack.**



SOURCE: Dyn

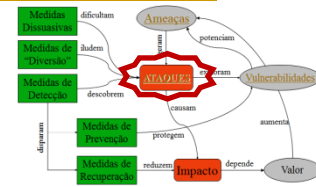
Threats



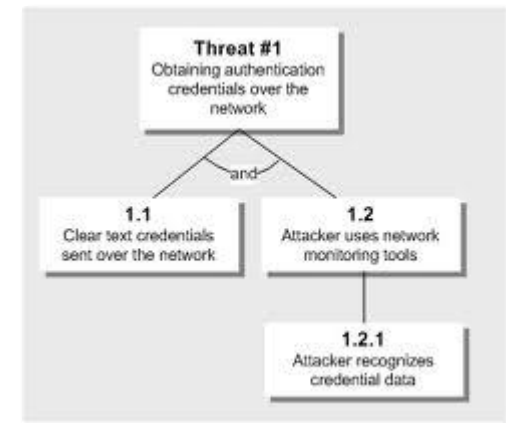
- What threats impend on (critical) resources?
 - Availability (and Utility) – **Interruption** (or disruption*)
 - Destruction, damage, or contamination
 - Refusal or delay in access
 - Dislocation or obscuration
 - Integrity (and Authenticity) – **Modification / Fabrication** (or deception* and usurpation*)
 - Insert or production of false data
 - Replacement, removal, separation or reorganization
 - Representation or encoding
 - Repudiation
 - Confidentiality (and Possession) – **Interception** (or disclosure*)
 - Illicit copy, observation, monitoring, or inference
 - Unwanted transfer of control or custody
 - Disclosure (in particular by legitimate users, by negligence or fraud)
- (*Taxonomy proposed by Shirey – Internet Security Glossary (2007))

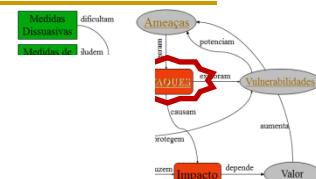
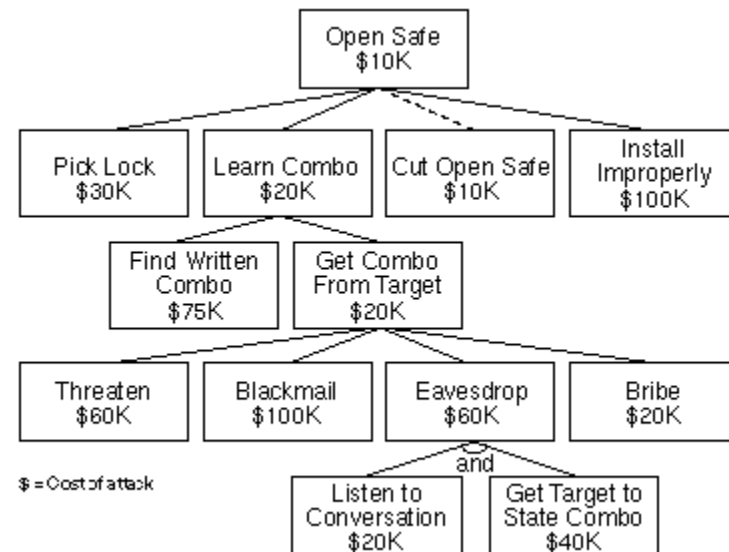
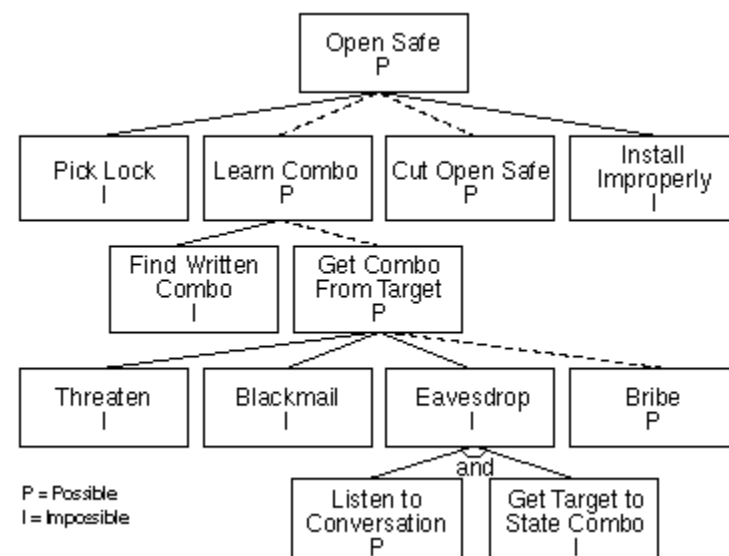
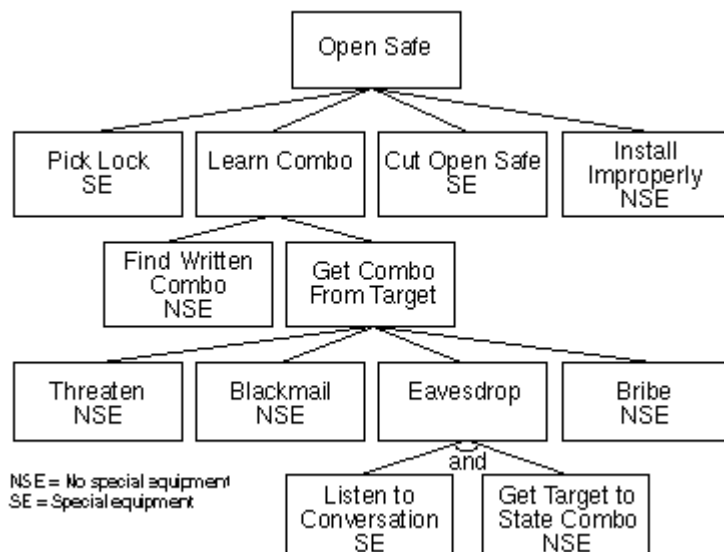
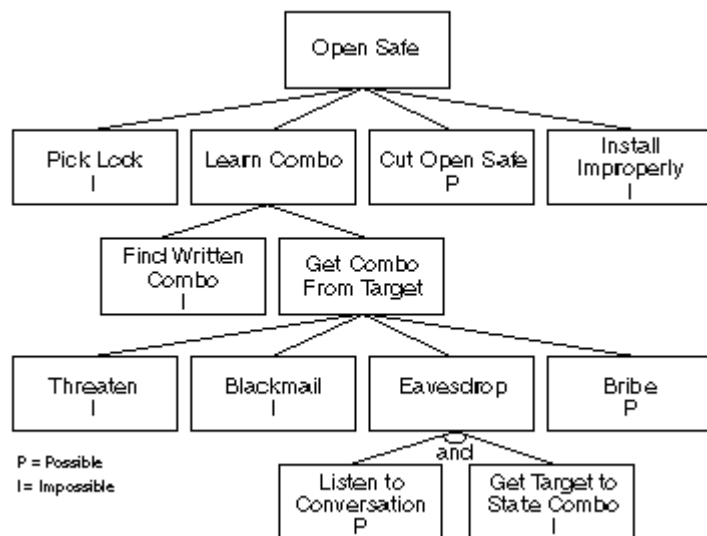


Attacks

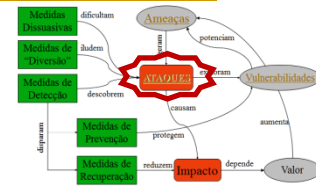


- An attack (or attacker) appears when there is:
 - ❑ **Method**: knowledge, skills and tools to exploit vulnerabilities
 - ❑ **Opportunity**: time and conditions to access
 - ❑ **Motive**: a reason to carry out the attack
- A well known analysis model: Tree Modeling Moore, AP (2001)
Tool: AttackTree++





Well known attacks



- Denial of Service (DoS/DDoS)
- Spam
- Mail Bombing
- Pharming
- Social Engineering
- Hoaxes and Phishing
- Malicious code (virus; Trojans; worms; ...)
- Back Doors
- Password Crack
- Man-in-the-Middle (or Hijacking)
- Spoofing
- Sniffers

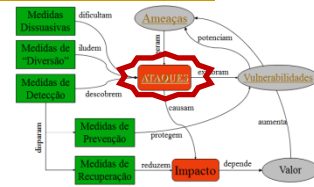
External (very difficult to avoid)

External (targeted to users)

Internal or external (affect machines)

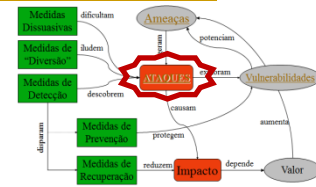
Internal (require access to LAN)

Well known attacks



- Harder to recognize attacks:
 - ❑ Human error
 - ❑ Failures in the design of Information Systems
 - ❑ Violation of safe places by "trustable people"
 - ❑ Intrusions
 - ❑ Natural disasters
- Some important efforts to "normalize" the description of attacks:
 - ❑ <http://capec.mitre.org/data/index.html>
 - ❑ [MITRE ATT&CK](#)

Attackers



- Concerning Information Systems, who are the attackers?
 - ❑ **Amateur**: driven by curiosity and the prospect of social role
 - ❑ **Crackers and Hackers**: often students, with high technical expertise; typically, they want to take over computers, for mere pleasure or for any economic advantage; often organized in Internet communities
 - ❑ **Criminals**: there is some evidence that organized crime, and international groups have been increasing its involvement in computer crime (the profit opportunities are increasing)
 - ❑ **Terrorists**: increasingly evident and at various levels
 - Targeting ISs as critical infra-structures
 - Using ISs as a mean of propaganda
 - Using ISs as a mean of attack



Vulnerabilities

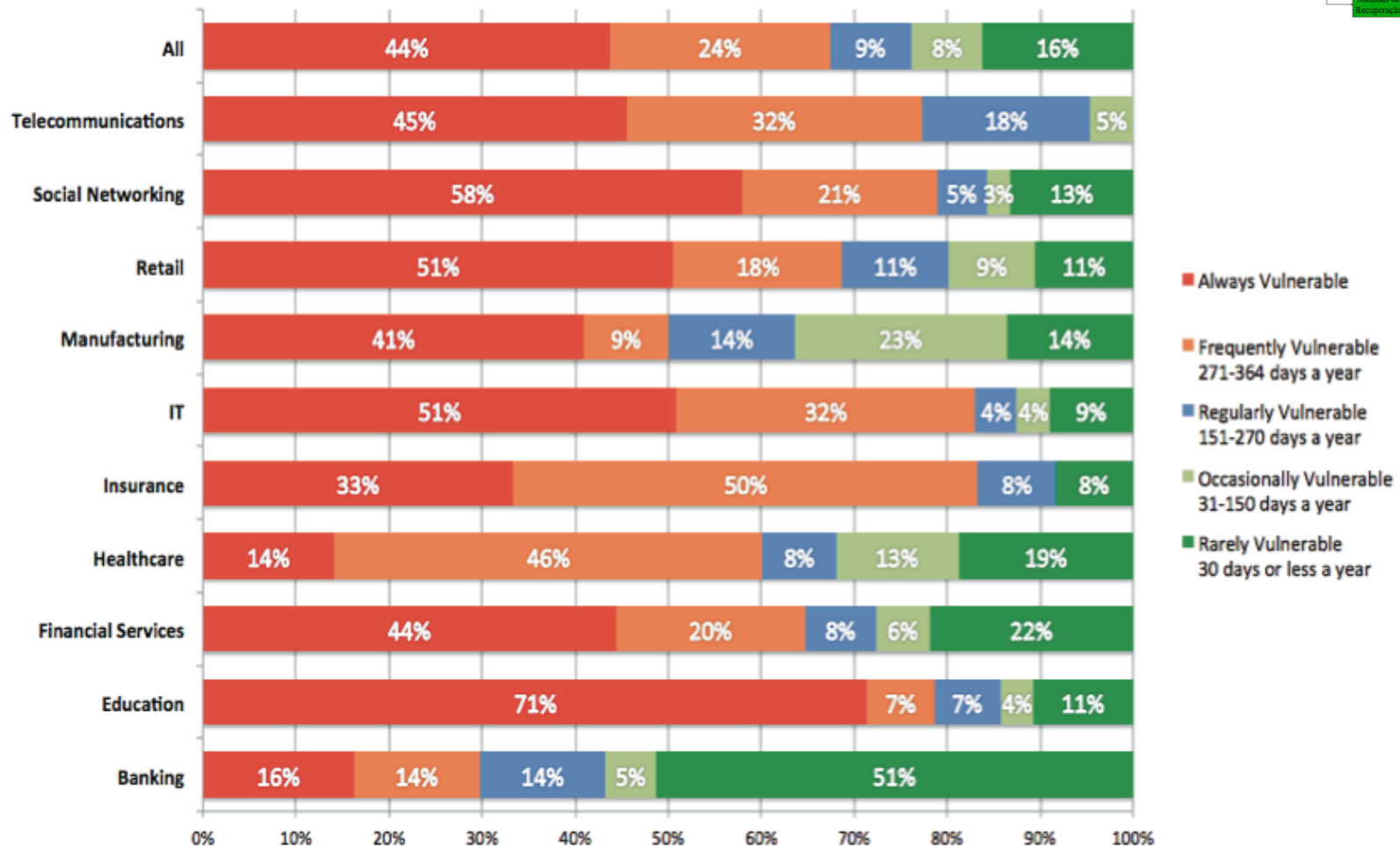


Figure 2. Window of Exposure by Industry (2010)

Source: <http://jeremiahgrossman.blogspot.pt/2011/03/11th-whitehat-website-security.html>



Vulnerabilities



■ Vulnerabilities origin

- ❑ An IS is generally made of **hardware** (execute simple instructions and transactions), **software** (create operations as logical sequences of instructions and transactions) and **data** (information)

❑ Computer Systems

- **Complexity**, degree of autonomy, miniaturization and dematerialization, ubiquity, **interconnect**, are factors that contribute to increased vulnerability
- Vulnerabilities detection/management support
 - ❑ Tools like NESSUS, SAINT, Grabber,...
 - ❑ Resources like CVS, NIST, SANS

-

[CVE LIST](#)[COMPATIBILITY](#)[NEWS — JULY 30, 2014](#)[SEARCH](#)

Common Vulnerabilities and Exposures

The Standard for Information Security Vulnerability Names

CVE-IDs have a new format –**[Click here to see the new format](#)**

TOTAL CVEs: **63391**

[HOME](#) > [CVE LIST](#)

About CVE

[Terminology](#)
[Documents](#)
[FAQs](#)

CVE List

[CVE-ID Syntax Change](#)
[About CVE Identifiers](#)
[Search CVE](#)
[Search NVD](#)
[Updates & RSS Feeds](#)
[Request a CVE-ID](#)

CVE In Use

[CVE-Compatible Products](#)
[NVD for CVE Fix Information](#)
[CVE Numbering Authorities](#)

News & Events

[Calendar](#)
[Free Newsletter](#)

Community

[CVE Editorial Board](#)
[Sponsor](#)
[Contact Us](#)

Search the Site

[Site Map](#)

CVE List Main Page

CVE® is a publicly available and free to use list or dictionary of standardized identifiers for common computer vulnerabilities and exposures.

IMPORTANT: [CVE-ID Syntax Change](#) took effect on January 1, 2014.

National Vulnerability Database

Full database functionality for the CVE List is provided through MITRE's partnership with the U.S. [National Vulnerability Database \(NVD\)](#).

- [CVE Search on NVD](#)
- [CVE Fix Information](#)
- [CVE SCAP Mappings](#)

CVE List Master Copy

The master copy of the CVE List is maintained for the community by MITRE on this public CVE Web site.

- [Search Master Copy of CVE](#)
- [Download CVE List](#)
- [View CVE List](#)

You may download the CVE List, copy it, redistribute it, reference it, and analyze it, provided you **do not modify** CVE itself as per our [Terms of Use](#). CVE and NVD are both sponsored by the [office of Cybersecurity and Communications](#) at the [U.S. Department of Homeland Security](#).

Page Last Updated: January 22, 2014



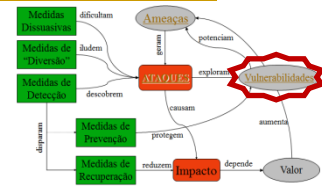
Use of the Common Vulnerabilities and Exposures List and the associated references from this Web site are subject to the [Terms of Use](#). For more information, please email cve@mitre.org.

CVE is co-sponsored by the office of [Cybersecurity and Communications](#) at the U.S. Department of Homeland Security. Copyright © 1999–2014, [The MITRE Corporation](#). CVE and the CVE logo are registered trademarks and CVE-Compatible is a trademark of The MITRE Corporation. This Web site is sponsored and managed by [The MITRE Corporation](#) to enable stakeholder collaboration.

[Site Map](#)
[Privacy policy](#)
[Terms of use](#)
[Contact us](#)

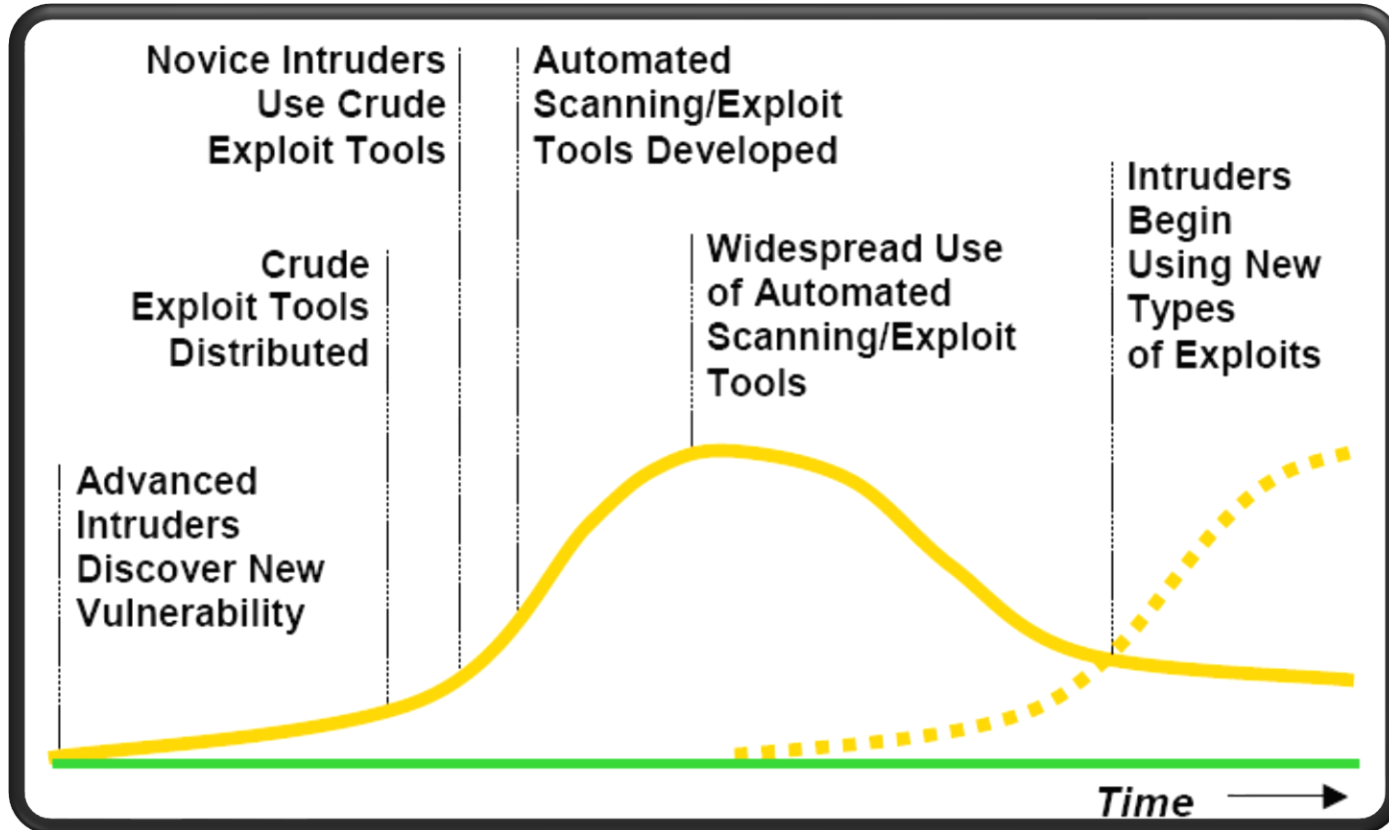


Vulnerabilities



- Vulnerabilities origin (cont)
 - ❑ Inadequate user behaviors
- Vulnerabilities recognition can derive from reflection on what can go wrong
 - ❑ Interruptible
 - ❑ Modifiable
 - ❑ “Manufacturable”
 - ❑ “Interceptable”
 - ❑ Incomplete (incomplete or misunderstood specifications)
 - ❑ ...

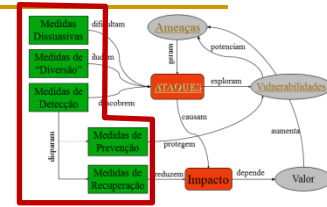
Cycle of vulnerabilities exploitation



Fonte: H.F. Lipson, CERT Coordination Center, CMU/DEI-2002-SR-009



Security Controls



■ Security properties driven classification

□ CIA oriented

- **User and organization policies**
- Access Control
 - Users; Networks; Applications; Physical
- Antivirus and antimalware
- Intrusion Detection Systems (IDS)

□ CI oriented

- Cryptography, Digital Signatures; Digital Certificates

□ IA oriented

- Backups

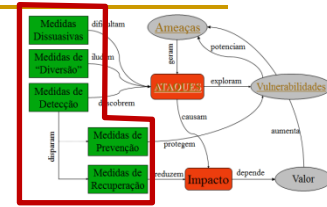
□ A oriented

- Disaster Recovery
- Redundancy (data and services)

□ I oriented

- Integrity verifiers

Security Controls



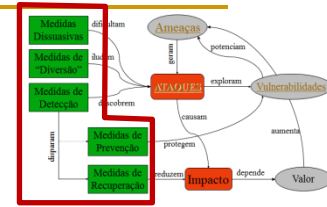
- **Policies, procedures, guides**, good practices, **hardware and software devices** or even organizational initiatives aiming to manage risk ...

Definition: *A **security policy** is a statement of what is, and what is not, allowed.* (Bishop, 2018)

- Organizational oriented
 - ❑ **Resources** are main targets
 - ❑ Objectives: **what to assure**

El diagrama de flujo ilustra la metodología de evaluación de riesgos de la biodiversidad. En el lado izquierdo, se listan cinco tipos de medidas: Medidas Dissuasivas, Medidas de "Diversa", Medidas de Detección, Medidas de Prevención y Medidas de Recuperación. Estas medidas influyen directamente en el riesgo. El riesgo se evalúa considerando Amenazas, Vulnerabilidades e Impacto. Las Amenazas y Vulnerabilidades interactúan entre sí y con el riesgo. El riesgo también interactúa con el Impacto, que a su vez depende del Valor.

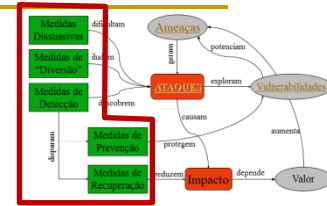
Security Controls



- Policies or procedures in use:
 - ❑ Password management policies – 74%
 - ❑ Inappropriate use policies – 71%
 - ❑ Education and awareness policies – 67%
 - ❑ Internet access monitoring – 65%
 - ❑ Corporate security policies – 62%
 - ❑ Risk Management practices – $\approx$ 55%
 - ❑ ...
 - ❑ Employing ex-hackers – 14%

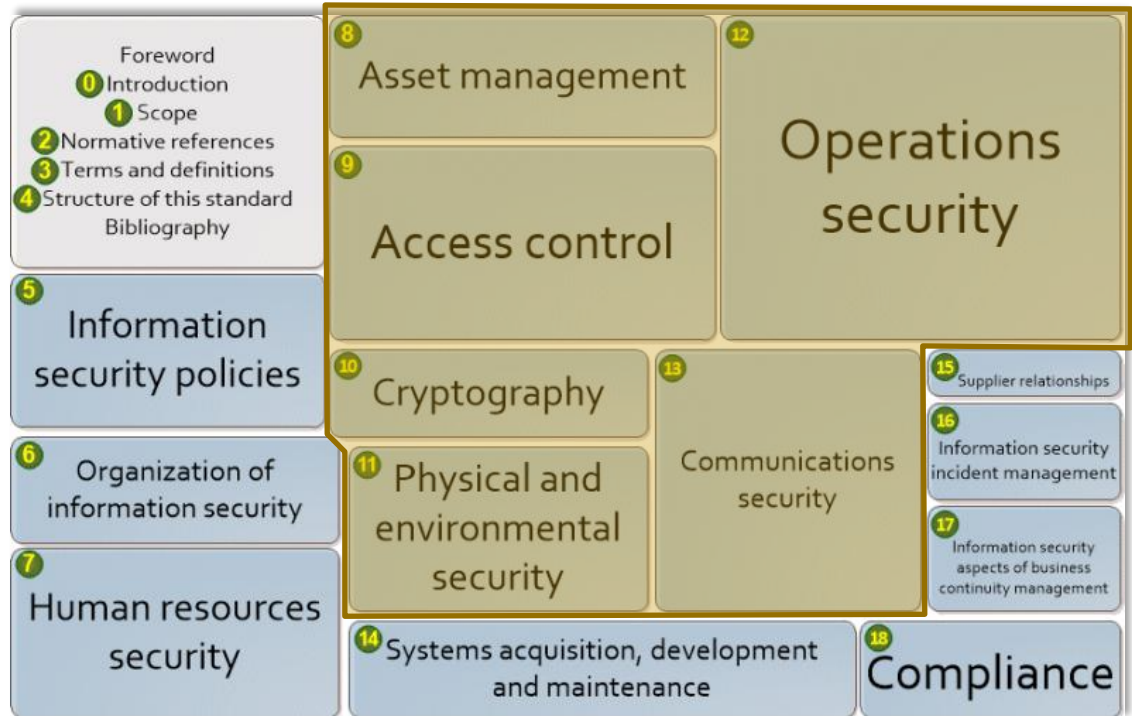
Source: 2005 E-Crime Watch Survey – CSO magazine

Security Controls



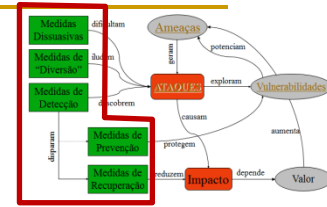
■ ISO/IEC 27002:2013 (Code of Practice for InfoSec Management)

- ❑ 14 classes (clauses) – sections 5 to 18
- ❑ 34 control objectives
- ❑ 124 security controls
- ❑ About one half are technological
- ❑ About one half are organizational or managerial



<http://www.iso27001security.com/html/27002.html>

Security Controls

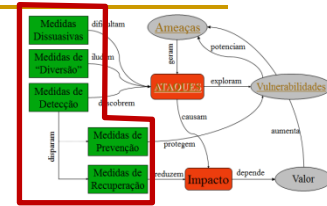


■ Other reference documents:

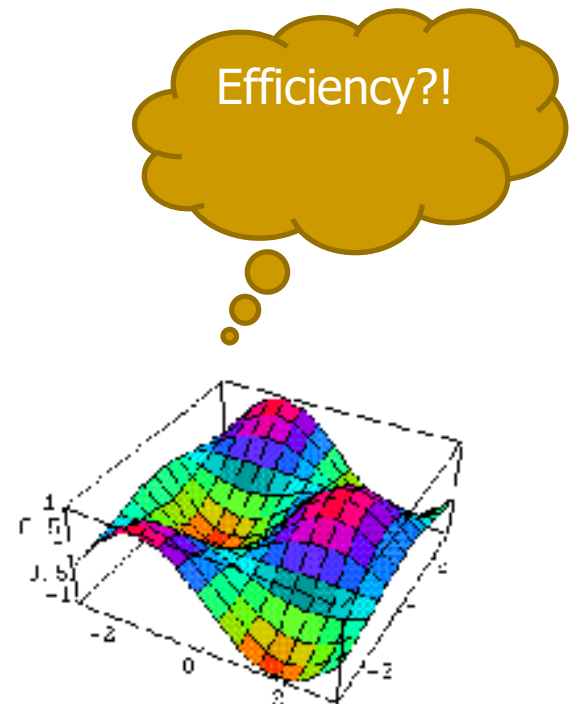
- ❑ NIST SP 800-53 (mandatory Security Controls for federal agencies in the USA)
 - SP 800-53 R4, also known as CSF (Cyber Security Framework), contains more than 900 controls, arranged in 5 categories
- ❑ CIS Controls (also known as CIS Critical Security Controls, or CIS/SAN 20)
 - prioritized set of 20 actions (best-practices)
- ❑ COBIT; PCI/DSS...



Security Controls

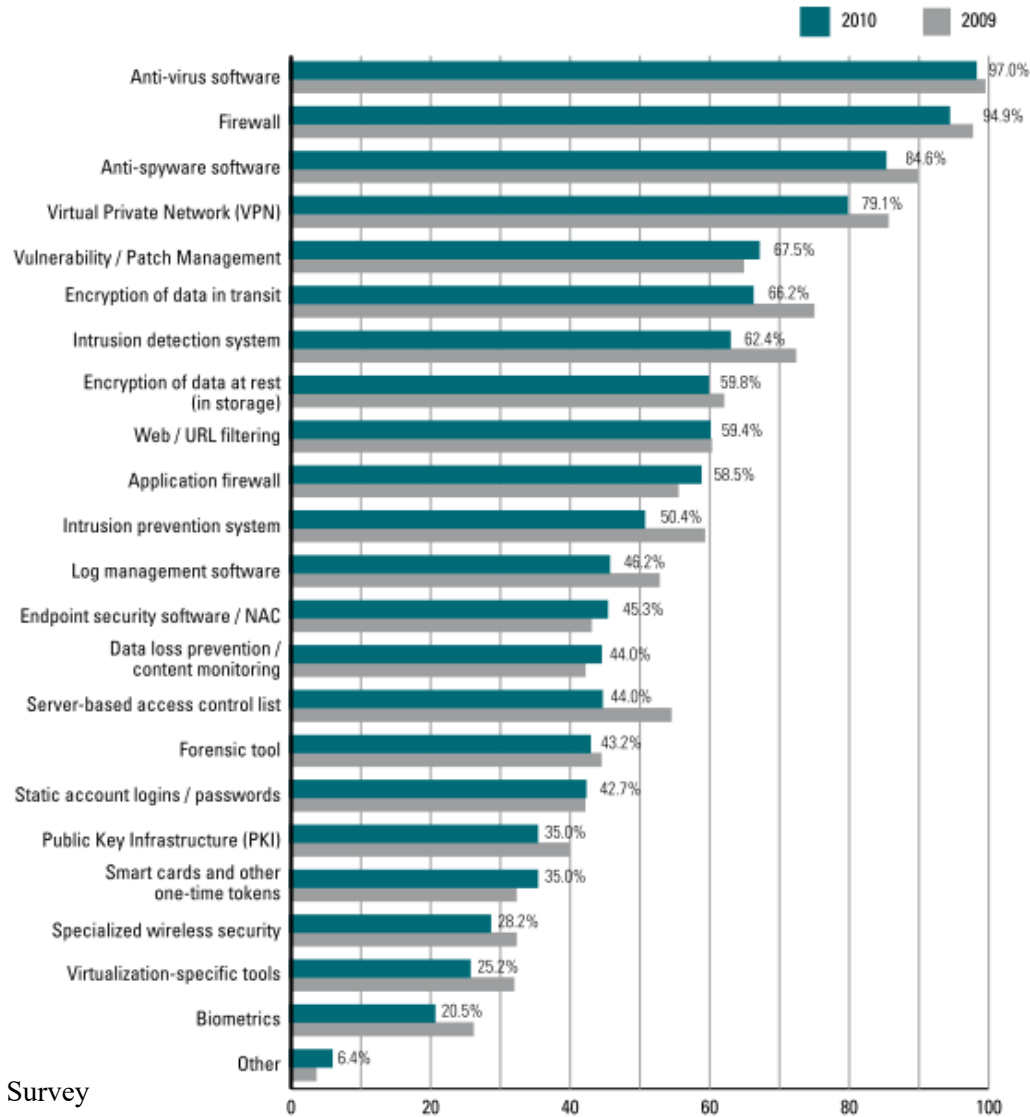


- Most used security technologies :
 - ❑ Antivirus – 97%
 - ❑ Antispam – 95%
 - ❑ **Firewalls** – 94%
 - ❑ Virtual Private Network (VPN) – 85%
 - ❑ Antispyware/adware – 80%
 - ❑ **Cipher (data in transit)** – 71% (↑)
 - ❑ Intrusion Detection (IDS) – 69%
 - ❑ Vulnerability scanners and patch – 65%
 - ❑ Web/URL filtering – 61%
 - ❑ **Application level Firewalls** – 53% (↑)
 - ❑ ...
 - ❑ PKI – 36%
 - ❑ Smartcards and other OTP devices – 36%
 - ❑ **Integrated NAC solutions** – 34% (↑)
 - ❑ Virtualization specific tools – 29%
 - ❑ **Wireless tools** – 27% (↓)
 - ❑ Biometrics – 23%



Source: CSI Computer Crime & Security Survey, 2008 → https://en.wikipedia.org/wiki/Cybersecurity_information_technology_list

Types of Security Technology Used By Percent of Respondents



Efficiency?!

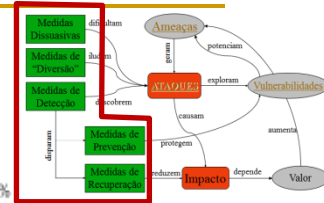
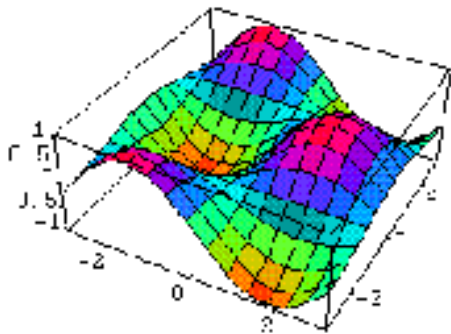
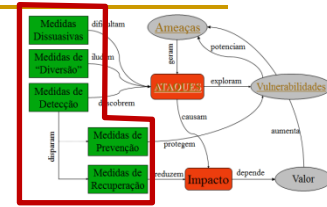


Diagrama de flujo que muestra la relación entre Amenazas, Vulnerabilidades, Impacto y Valor. Las Amenazas (gases de efecto invernadero, contaminación, pérdida de biodiversidad, etc.) interactúan con las Vulnerabilidades (sistemas naturales, humanos, socioeconómicos) a través de la Exposición y el Riesgo. El Riesgo (Riesgo = Amenazas x Vulnerabilidades x Exposición) conduce al Impacto (Impacto = Riesgo x Exposición). El Impacto afecta el Valor (Valor = Impacto x Dependencia). Las Medidas de Mitigación (reducción de emisiones, conservación, etc.) actúan sobre las Amenazas. Las Medidas de Adaptación (mejora de infraestructura, etc.) actúan sobre las Vulnerabilidades. Las Medidas de Preparación (planes de emergencia, etc.) actúan sobre el Impacto. Las Medidas de Recuperación (restauración de ecosistemas, etc.) actúan sobre el Valor.

- 68

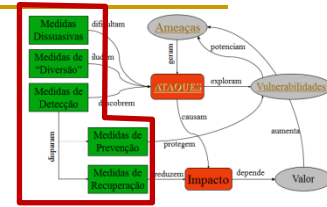
Controls' efficiency



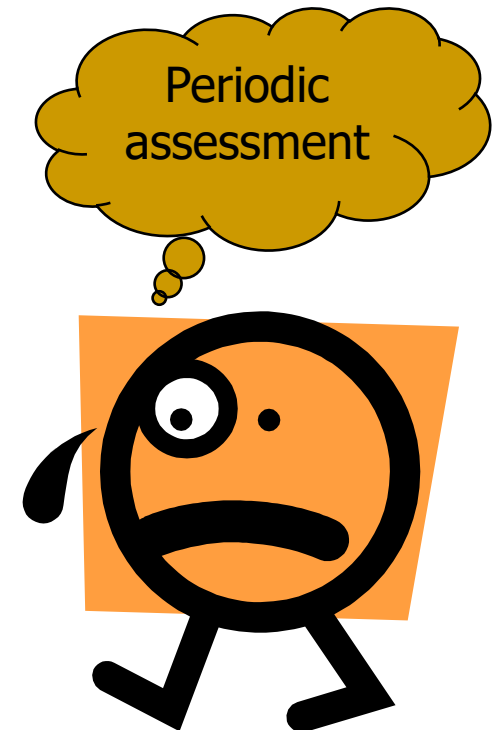
- Techniques used to evaluate efficiency
 - ❑ Internal auditing (82%)
 - ❑ Penetration test (66%)
 - ❑ Automatic tools (66%)
 - ❑ External auditing (62%)
 - ❑ Monitoring software:
 - e-mails (61%)
 - Web activity (58%)

What exactly is
being
measured?

Controls' effectiveness

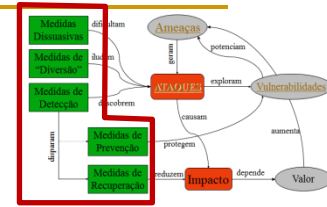


- More effective technologies:
 - ❑ *Firewalls* – 68%
 - ❑ *Anti-Vírus* – 66%
 - ❑ *Cipher* – 58%
 - ❑ *Two-phase authentication* – 56%
 - ❑ *Intrusion Detection (IDS)* – 50%
 - ❑ *Physical Security* – 49%
 - ❑ *Network traffic monitoring* – 46%
 - ❑ *Spyware/Adware* – 43%
 - ❑ ...
 - ❑ *Manual patches* – 26%



Source: 2005 E-Crime Watch Survey – CSO magazine

About metrics

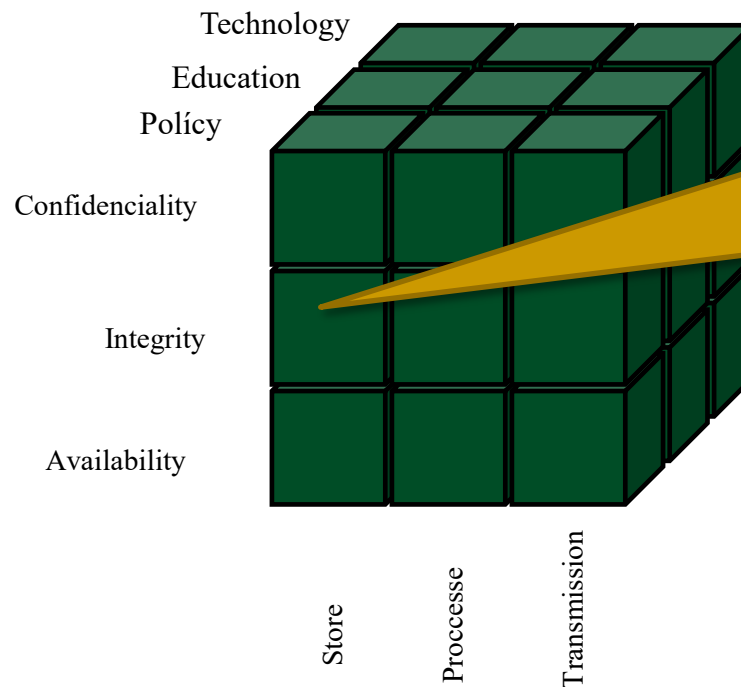


- NIST SP800-55 (*Security Metrics Guide for Information Technology Systems*) defines three metric types:
 - Implementation metrics
 - Efficacy/Efficiency metrics
 - Impact metrics
- ...
- A lot of (very hard) work to do ☹️



InfoSec Model

CNSS Model (*McCumber Cube*) - *Committee on National Security Systems*, a NSA group (NSTISSI-4011)



Involves the need for technology to protect the integrity of the stored data:
Exemples: HIDS, integrity checker software

InfoSec Model

- The previous approaches are centered on **effects**, but there are other possible perspectives (e.g., centered on environmental factors):

“The absence of threats that can affect our expectations about information systems equivalently protected in equivalent environments.”

(Canal, 2005)

About Models

*“All Models Are Wrong But
Some Are Useful”*

Author: George Box

Regulatory Compliance

■ Internacional



- ISO/IEC 17799 / **27000 family**
- **27th January – International ISO/IEC 27001 Day**

■ USA



- Federal Information Security Management Act (FISMA)
- **Health Insurance Portability and Accountability Act (HIPAA)**
- NIST – Computer Division SP-800 family
- Sarbanes–Oxley Act; Gramm–Leach–Bliley Act; COBIT

■ Australia and the UK also have their own normalization bodies

■ National

- LPD (Law for Data Protection – “Lei 67/98”) which transcribe the EU Directive 95/46/CE
- SEGNAC 1 and 4 published by GNS (QG of Centro Nacional de Cibersegurança)

27000 Standards' family

InfoSec is a
Management
Process!

<u>ISO/IEC 27000</u> overview & vocabulary	<u>ISO/IEC 27013</u> for ISMS+service mgmt
<u>ISO/IEC 27001</u> formal ISMS specification	<u>ISO/IEC 27014</u> on infosec governance
<u>ISO/IEC 27002</u> infosec controls guideline	<u>ISO/IEC TR 27015</u> for financial services
<u>ISO/IEC 27003</u> implementation guidance	<u>ISO/IEC 27031</u> business continuity
<u>ISO/IEC 27004</u> infosec metrics	<u>ISO/IEC 27032</u> cybersecurity
<u>ISO/IEC 27005</u> infosec risk management	<u>ISO/IEC 27033</u> network security
<u>ISO/IEC 27006</u> ISMS certification guide	<u>ISO/IEC 27034</u> application security
<u>ISO/IEC 27007</u> MS auditing guide	<u>ISO/IEC 27035</u> incident management
<u>ISO/IEC TR 27008</u> technical auditing	<u>ISO/IEC 27037</u> digital evidence
<u>ISO/IEC 27010</u> for inter-org comms	<u>ISO 27799</u> ISO27k for healthcare industry
<u>ISO/IEC 27011</u> ISO27k for telecomms	

<http://www.iso27001security.com/>

Regulatory Compliance

- Many regulations provide some kind of “***baseline security control***”
 - Ex: Payment Card Industry Data Security Standard (PCI DSS); NSA; Cisco;...
- But...
 - To what extent this set of controls is aligned with reality?
 - Once in compliance means compliance forever?

Security evaluation

■ Example: *Common Criteria* (ISO/IEC 15408)

Level of Assessment	Characteristic
EAL7	Formal methodology for both project and test
EAL6	Semi-formal methodology for both project and test
EAL5	Methodologically projected, supported by a semi-formal test
EAL4	Methodologically designed, tested, verified and reviewed
EAL3	Methodologically tested and verified
EAL2	Structural test (module interconnection)
EAL1	Functional test

Qualitative



- ◆ Now we have a model. What's next?
- ◆ We still need to understand better the security technology available and how to use it correctly...
- ◆ Long and hard way...

